

Linux STIG-Style Security Audit and Hardening Review

1. Introduction

Purpose of the Audit

This project demonstrates a Linux STIG-style security audit performed on an Ubuntu Linux system hosted in the TryHackMe Linux Fundamentals Part 3 environment. The goal of the audit was to review the system's security posture by examining user accounts, running services, authentication settings, cron jobs, firewall-related configurations, system logs, and file permissions.

The assessment follows a defensive security and governance-focused approach similar to Security Technical Implementation Guides (STIGs) used in enterprise and government environments. Rather than exploiting vulnerabilities, the project focuses on identifying system configurations, validating security settings, and documenting findings that could affect confidentiality, integrity, and availability.

The audit also demonstrates practical Linux administration and cybersecurity skills including:

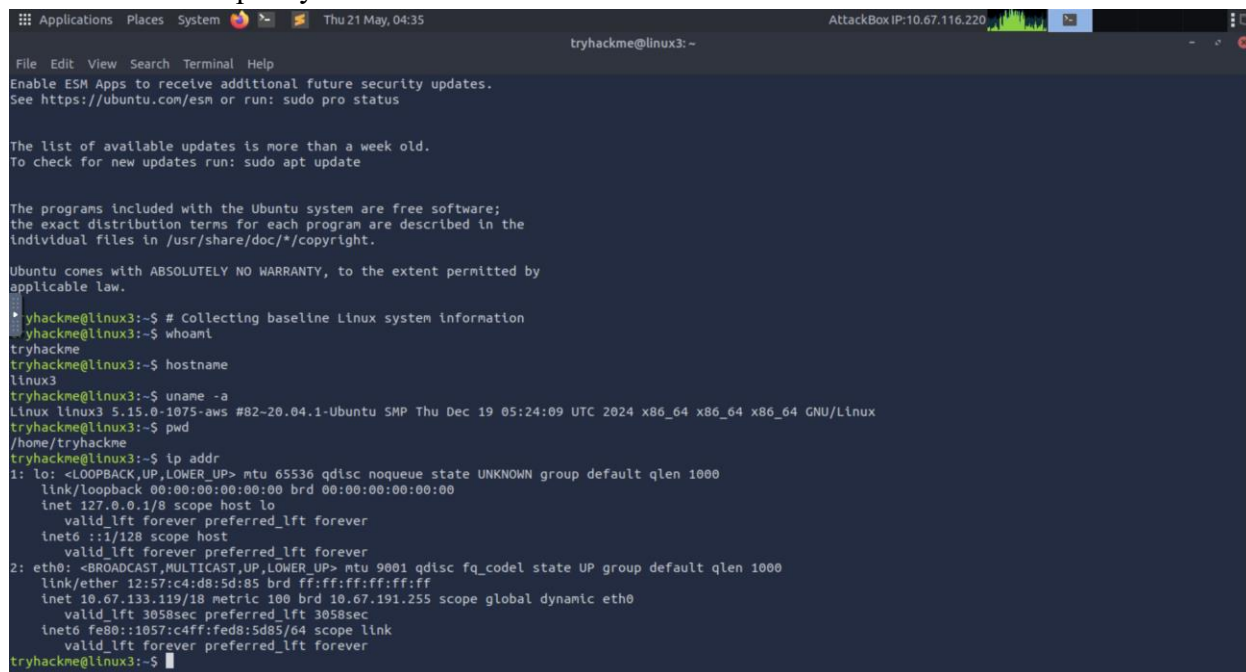
- System enumeration
- Log analysis
- Service auditing
- User and privilege review
- Network service inspection
- File permission validation
- Security configuration review

Scope

The audit was performed against a Linux virtual machine provided through the TryHackMe AttackBox environment. The review included:

- Operating system and kernel identification
- Running processes and services
- SSH configuration analysis
- User account and privilege auditing
- Scheduled cron job inspection
- Log monitoring review
- File permission checks

- Network service enumeration
- Installed security package verification
- Password policy review



The screenshot shows a terminal window titled 'tryhackme@linux3: ~'. The window displays the output of several commands used to collect baseline system information. At the top, there are system messages about ESM apps and updates. The user then runs 'whoami', 'hostname', 'uname -a', 'pwd', and 'ip addr'. The 'ip addr' command shows details for the loopback interface 'lo' and the ethernet interface 'eth0'.

```

File Edit View Search Terminal Help
Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

tryhackme@linux3:~$ # Collecting baseline Linux system information
tryhackme@linux3:~$ whoami
tryhackme
tryhackme@linux3:~$ hostname
linux3
tryhackme@linux3:~$ uname -a
Linux linux3 5.15.0-1075-aws #82-20.04.1-Ubuntu SMP Thu Dec 19 05:24:09 UTC 2024 x86_64 x86_64 x86_64 GNU/Linux
tryhackme@linux3:~$ pwd
/home/tryhackme
tryhackme@linux3:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc fq_codel state UP group default qlen 1000
    link/ether 12:57:c4:d8:5d:85 brd ff:ff:ff:ff:ff:ff
    inet 10.67.133.119/18 metric 100 brd 10.67.191.255 scope global dynamic eth0
        valid_lft 3058sec preferred_lft 3058sec
    inet6 fe80::1057:c4ff:fed8:5d85/64 scope link
        valid_lft forever preferred_lft forever
tryhackme@linux3:~$

```

Figure 1. Initial Linux system baseline inventory including hostname, kernel version, and network configuration.

Tools and Commands Used

The following Linux utilities and commands were used during the assessment:

- whoami
- hostname
- uname
- ip addr
- ps aux
- systemctl
- grep
- cat
- crontab
- ls
- ss
- dpkg
- find
- df
- last

- lsmod

2. Active Process and Service Enumeration

Process Monitoring Review

The first stage of the audit involved reviewing active processes running on the Linux system using the `ps aux` command. Process enumeration is an important security auditing task because it allows administrators and security analysts to identify running applications, background services, active user sessions, and potentially suspicious activity occurring within the operating system.

The output showed several critical system processes related to:

- SSH access
- cron scheduling
- logging services
- user shell sessions
- background daemons

Reviewing active processes helps improve operational visibility and supports threat detection, incident response, and Linux hardening activities.

```

tryhackme@linux3:~$ ps aux
USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root             1  0.2  0.6 103724 12472 ?        Ss   03:26   0:01 /sbin/init
root             2  0.0  0.0      0   0 ?        S   03:26   0:00 [kthreadd]
root             3  0.0  0.0      0   0 ?        I<   03:26   0:00 [rcu_gp]
root             4  0.0  0.0      0   0 ?        I<   03:26   0:00 [rcu_par_gp]
root             5  0.0  0.0      0   0 ?        I<   03:26   0:00 [slub_flushwq]
root             6  0.0  0.0      0   0 ?        I<   03:26   0:00 [netns]
root             8  0.0  0.0      0   0 ?        I<   03:26   0:00 [kworker/0:0H-events_highpri]
root             9  0.0  0.0      0   0 ?        I   03:26   0:00 [kworker/u30:0-events_power_efficient]
root            10  0.0  0.0      0   0 ?        I<   03:26   0:00 [mm_percpu_wq]
root            11  0.0  0.0      0   0 ?        S   03:26   0:00 [rcu_tasks_rude_]
root            12  0.0  0.0      0   0 ?        S   03:26   0:00 [rcu_tasks_trace]
root            13  0.0  0.0      0   0 ?        S   03:26   0:00 [ksortirqd/0]
root            14  0.0  0.0      0   0 ?        I   03:26   0:00 [rcu_sched]
root            15  0.0  0.0      0   0 ?        S   03:26   0:00 [migration/0]
root            16  0.0  0.0      0   0 ?        S   03:26   0:00 [idle_inject/0]
root            18  0.0  0.0      0   0 ?        S   03:26   0:00 [cpuhp/0]
root            19  0.0  0.0      0   0 ?        S   03:26   0:00 [kdevtmpfs]
root            20  0.0  0.0      0   0 ?        I<   03:26   0:00 [inet_frag_wq]
root            21  0.0  0.0      0   0 ?        S   03:26   0:00 [kauditd]
root            22  0.0  0.0      0   0 ?        S   03:26   0:00 [khungtaskd]
root            23  0.0  0.0      0   0 ?        S   03:26   0:00 [oom_reaper]
root            24  0.0  0.0      0   0 ?        I<   03:26   0:00 [writeback]
root            25  0.0  0.0      0   0 ?        S   03:26   0:00 [kcompactd]
root            26  0.0  0.0      0   0 ?        SN   03:26   0:00 [ksmd]
root            27  0.0  0.0      0   0 ?        SN   03:26   0:00 [khugepaged]
root            28  0.0  0.0      0   0 ?        I<   03:26   0:00 [kintegrityd]
root            34  0.0  0.0      0   0 ?        I<   03:26   0:00 [kblockd]
root            40  0.0  0.0      0   0 ?        I<   03:26   0:00 [blkcg_punt_bio]
root            46  0.0  0.0      0   0 ?        S   03:26   0:00 [xen-balloon]
root            47  0.0  0.0      0   0 ?        I<   03:26   0:00 [tpm_dev_wq]
root            48  0.0  0.0      0   0 ?        I<   03:26   0:00 [ata_sff]
root            49  0.0  0.0      0   0 ?        I<   03:26   0:00 [nd]
root            50  0.0  0.0      0   0 ?        I<   03:26   0:00 [edac-poller]
root            51  0.0  0.0      0   0 ?        I<   03:26   0:00 [devfreq_wq]
root            52  0.0  0.0      0   0 ?        S   03:26   0:00 [watchdogd]
root            53  0.0  0.0      0   0 ?        I<   03:26   0:00 [kworker/0:1H-kblockd]
root            86  0.0  0.0      0   0 ?        S   03:26   0:00 [kswapd0]
root            87  0.0  0.0      0   0 ?        S   03:26   0:00 [ecryptfs-kthrea]
root            89  0.0  0.0      0   0 ?        I<   03:26   0:00 [kthrotld]
root            90  0.0  0.0      0   0 ?        I<   03:26   0:00 [acpi_thermal_pm]
root            91  0.0  0.0      0   0 ?        S   03:26   0:00 [xenbus]
root            92  0.0  0.0      0   0 ?        S   03:26   0:00 [xenwatch]
root            93  0.0  0.0      0   0 ?        I<   03:26   0:00 [nvme-wq]
root            94  0.0  0.0      0   0 ?        I<   03:26   0:00 [nvme-reset-wq]
root            95  0.0  0.0      0   0 ?        I<   03:26   0:00 [nvme-delete-wq]
root            96  0.0  0.0      0   0 ?        S   03:26   0:00 [scsi_ah_0]
root            97  0.0  0.0      0   0 ?        I<   03:26   0:00 [scsi_tmf_0]
root            98  0.0  0.0      0   0 ?        S   03:26   0:00 [scsi_ah_1]
root            99  0.0  0.0      0   0 ?        I<   03:26   0:00 [scsi_tmf_1]
root           101  0.0  0.0      0   0 ?        I   03:26   0:00 [kworker/u30:3-events_unbound]
root           102  0.0  0.0      0   0 ?        I<   03:26   0:00 [vrfio-trqd-clea]
root           103  0.0  0.0      0   0 ?        I<   03:26   0:00 [nld]
root           104  0.0  0.0      0   0 ?        I<   03:26   0:00 [ip6v_addrconf]
root           114  0.0  0.0      0   0 ?        I<   03:26   0:00 [kstrp]
root           117  0.0  0.0      0   0 ?        I<   03:26   0:00 [zswap-shrink]
root           119  0.0  0.0      0   0 ?        I<   03:26   0:00 [kworker/u31:0]
root           123  0.0  0.0      0   0 ?        I<   03:26   0:00 [charger_manager]
root           124  0.0  0.0      0   0 ?        S   03:26   0:00 [jbd2/xvda1-8]
root           125  0.0  0.0      0   0 ?        I<   03:26   0:00 [ext4-rsv-conver]
root           166  0.1  0.8 52160 16576 ?        Ss   03:26   0:00 /lib/systemd/systemd-journald
root           190  0.0  0.0      0   0 ?        I   03:26   0:00 [kworker/0:3-events]
root           199  0.0  0.2 9944 5940 ?        S   03:26   0:00 /lib/systemd/systemd-udev
root           216  0.0  0.0      0   0 ?        I<   03:26   0:00 [cryptd]
root           293  0.0  0.0      0   0 ?        I<   03:26   0:00 [kaluad]
root           294  0.0  0.0      0   0 ?        I<   03:26   0:00 [kmpath_rdcad]
root           295  0.0  0.0      0   0 ?        I<   03:26   0:00 [kmpathd]
root           296  0.0  0.0      0   0 ?        I<   03:26   0:00 [kmpath_handlerd]
root           297  0.0  0.8 280208 18004 ?        SLsl 03:26   0:00 /sbin/multipathd -d -s
root           328  0.0  0.3 90896 6092 ?        Ssl 03:26   0:00 /lib/systemd/systemd-timesyncd
root           408  0.0  0.3 27284 7424 ?        Ss   03:26   0:00 /lib/systemd/systemd-networkd
root           410  0.0  0.6 24828 12424 ?        Ss   03:26   0:00 /lib/systemd/systemd-resolved
root           457  0.0  0.3 237336 7260 ?        Ssl 03:26   0:00 /usr/lib/accounts-service/accounts-daemon
root           458  0.0  0.0 2548 716 ?        S   03:26   0:00 /usr/sbin/acpid
root           461  0.0  0.1 8548 2716 ?        Ss   03:26   0:00 /usr/sbin/cron -f
root           462  0.0  0.2 7580 4672 ?        Ss   03:26   0:00 /usr/sbin/dbus-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation
root           473  0.0  0.9 29872 18500 ?        Ss   03:26   0:00 /usr/bin/python3 /usr/bin/networkd-dispatcher --run-startup-triggers
root           474  0.0  0.4 234592 8700 ?        Ssl 03:26   0:00 /usr/lib/policykit-1/polkitd --no-debug
root           476  0.0  0.1 10224 3400 ?        S   03:26   0:00 /usr/sbin/cron -f
root           478  0.0  0.2 224500 5076 ?        Ssl 03:26   0:00 /usr/sbin/rsyslogd -n -iNONE
root           480  0.0  0.9 1759116 18332 ?        Ssl 03:26   0:00 /snap/amazon-ssm-agent/9881/amazon-ssm-agent
root           485  0.0  1.4 1247372 29756 ?        Ssl 03:26   0:00 /usr/lib/snapd/snapd
root           488  0.0  0.3 17320 7712 ?        Ss   03:26   0:00 /lib/systemd/systemd-logind
root           492  0.0  0.6 393152 12084 ?        Ssl 03:26   0:00 /usr/lib/udisks2/udisksd
root           498  0.0  0.0      0   0 ?        I   03:26   0:00 [kworker/0:5-cgroup_destroy]
root           499  0.0  0.1 3804 2160 ?        Ss   03:26   0:00 /usr/sbin/atd -f
root           509  0.0  0.1 7360 2300 ttyS0  Ss+  03:26   0:00 /sbin/agetty -o -p -- \u --keep-baud 115200,38400,9600 ttyS0 vt220
root           513  0.0  0.0 5836 1780 tty1  Ss+  03:26   0:00 /sbin/agetty -o -p -- \u --noclear tty1 linux
root           525  0.0  0.0 2616 596 ?        Ss   03:26   0:00 /bin/sh -c /root/process
root           535  0.0  0.5 241348 11396 ?        Ssl 03:26   0:00 /usr/sbin/ModemManager
root           537  0.0  0.0 2364 572 ?        S   03:26   0:00 THM[PROCESSES]
root           597  0.0  1.0 108144 20580 ?        Ssl 03:26   0:00 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-sign
root           787  0.1  1.3 1768940 27564 ?        SL   03:26   0:00 /snap/amazon-ssm-agent/9881/ssm-agent-worker
root           816  0.0  0.3 12196 6868 ?        Ss   03:26   0:00 sshd: /usr/sbin/sshd -D -o AuthorizedKeysCommand /usr/share/ec2-instance-connect/etc_run_au
root           962  0.0  0.0      0   0 ?        I   03:33   0:00 [kworker/u30:1-ext4-rsv-conversion]
root           964  0.0  0.4 13944 9128 ?        Ss   03:34   0:00 sshd: tryhackme [prlv]
tryhack+      967  0.0  0.4 18936 9536 ?        Ss   03:34   0:00 /lib/systemd/systemd --user
tryhack+      968  0.0  0.2 104940 4380 ?        S   03:34   0:00 (sd-pam)
tryhack+     1076  0.0  0.2 14080 5896 ?        S   03:34   0:00 sshd: tryhackme@pts/0
tryhack+     1077  0.0  0.2 10044 5092 pts/0  Ss   03:34   0:00 -bash
tryhack+     1105  0.0  0.1 10620 3344 pts/0  R+   03:37   0:00 ps aux

```

Figure 2. Active Linux process enumeration using the ps aux command, including system daemons, service processes, and user session activity.

Enabled Service Enumeration

The `systemctl list-units --type=service` command was used to review enabled and running Linux services. Service auditing is a critical component of STIG-style hardening because unnecessary or insecure services can increase the attack surface of a system.

Several important services were identified during the review, including:

- `ssh.service`
- `cron.service`
- `rsyslog.service`
- `systemd-journald.service`

These services support remote administration, scheduled task execution, and centralized logging operations.

```

tryhackme@linux3:~$ systemctl list-units --type=service
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
acpid.service                      loaded active running ACPI event daemon
apparmor.service                   loaded active exited Load AppArmor profiles
apport.service                     loaded active exited LSB: automatic crash report generation
atd.service                        loaded active running Deferred execution scheduler
badr.service                       loaded active running Badr Service
blk-availability.service            loaded active exited Availability of block devices
cloud-config.service               loaded active exited Cloud-init: Config Stage
cloud-final.service                loaded active exited Cloud-init: Final Stage
cloud-init-local.service           loaded active exited Cloud-init: Local Stage (pre-network)
cloud-init.service                 loaded active exited Cloud-init: Network Stage
console-setup.service              loaded active exited Set console font and keymap
cron.service                       loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
finalrd.service                    loaded active exited Create final runtime dir for shutdown pivot root
getty@tty1.service                 loaded active running Getty on tty1
keyboard-setup.service             loaded active exited Set the console keyboard layout
kmod-static-nodes.service          loaded active exited Create list of static device nodes for the current kernel
lvm2-monitor.service               loaded active exited Monitoring of LVM2 mirrors, snapshots etc. using dmeventd or progress polling
ModemManager.service              loaded active running Modem Manager
multipath.service                  loaded active running Device-Mapper Multipath Device Controller
networkd-dispatcher.service        loaded active running Dispatcher daemon for systemd-networkd
polkit.service                     loaded active running Authorization Manager
rsyslog.service                    loaded active running System Logging Service
serial-getty@ttyS0.service         loaded active running Serial Getty on ttyS0
setvtrgb.service                   loaded active exited Set console scheme
snap.amazon-ssm-agent.amazon-ssm-agent.service loaded active running Service for snap application amazon-ssm-agent.amazon-ssm-agent
snapd.apparmor.service             loaded active exited Load AppArmor profiles managed internally by snapd
snapd.seeded.service               loaded active exited Wait until snapd is fully seeded
snapd.service                      loaded active running Snap Daemon
ssh.service                        loaded active running OpenBSD Secure Shell server
systemd-journal-flush.service       loaded active exited Flush Journal to Persistent Storage
systemd-journald.service           loaded active running Journal Service
systemd-logind.service             loaded active running Login Service
systemd-modules-load.service        loaded active exited Load Kernel Modules
systemd-networkd-wait-online.service loaded active exited Wait for Network to be Configured

```

Figure 3. Enumeration of enabled Linux system services using `systemctl`.

3. SSH Security Configuration Review

Secure Shell (SSH) is one of the most critical remote administration services in Linux environments. Misconfigured SSH settings can expose systems to unauthorized access, brute-

force attacks, and privilege escalation attempts. During this audit, the SSH daemon configuration file was reviewed to identify active security-related settings.

The review confirmed that:

- Password authentication was enabled
- PAM authentication support was enabled
- Challenge-response authentication was disabled
- SFTP subsystem functionality was configured

These settings demonstrate that SSH remote access functionality is operational on the system. However, password-based authentication may increase exposure to credential attacks if additional hardening controls such as MFA or key-based authentication are not implemented.

```
tryhackme@linux3:~$ # Reviewing SSH daemon configuration
tryhackme@linux3:~$ cat /etc/ssh/sshd_config | grep -v "^#" | grep -v "^$"
Include /etc/ssh/sshd_config.d/*.conf
PasswordAuthentication yes
ChallengeResponseAuthentication no
UsePAM yes
X11Forwarding yes
PrintMotd no
AcceptEnv LANG LC_*
Subsystem sftp /usr/lib/openssh/sftp-server
tryhackme@linux3:~$
```

Figure 4. SSH daemon configuration settings reviewed from the sshd_config file.

4. User and Privilege Auditing

User account auditing was performed by reviewing entries within the /etc/passwd file and identifying accounts configured with interactive login shells. User enumeration is important because unauthorized or unnecessary accounts may increase security risk and complicate access management.

The audit identified:

- the root account
- the ubuntu account
- the tryhackme account

The review also examined sudo group membership to determine which accounts possessed elevated administrative privileges.

Results showed that only the ubuntu account was assigned to the sudo administrative group, while the tryhackme account did not possess elevated privileges. Restricting administrative access supports the principle of least privilege and helps reduce the risk of unauthorized system modifications.

```
tryhackme@linux3:~$ # Reviewing local user accounts
tryhackme@linux3:~$ cat /etc/passwd | grep "/bin/bash"
root:x:0:0:root:/root:/bin/bash
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
tryhackme:x:1001:1001:::/home/tryhackme:/bin/bash
tryhackme@linux3:~$ # Reviewing sudo group membership
tryhackme@linux3:~$ getent group sudo
sudo:x:27:ubuntu
tryhackme@linux3:~$
```

Figure 5. Review of local user accounts and sudo group membership.

5. Scheduled Task and Cron Job Review

Scheduled tasks were reviewed using crontab and system cron directories. Cron jobs are commonly used in Linux systems to automate administrative tasks, updates, backups, and maintenance operations. However, improperly configured cron jobs may also create opportunities for persistence or privilege escalation.

The audit identified a reboot-based scheduled script execution associated with:

- /var/opt/processes.sh

System-wide cron directories were also reviewed to identify automatically scheduled maintenance jobs and package management tasks.

Several legitimate scheduled maintenance scripts were identified, including:

- Apache maintenance tasks
- package update operations
- log rotation services
- system database updates

Reviewing scheduled tasks is important because attackers often abuse cron functionality to maintain persistence after initial compromise.

```

tryhackme@linux3:~$ # Reviewing scheduled cron jobs
tryhackme@linux3:~$ crontab -l
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
@reboot /var/opt/processes.sh

tryhackme@linux3:~$ # Reviewing system cron directories
tryhackme@linux3:~$ ls -ls /etc/cron*
-rw-r--r-- 1 root root 1042 Feb 13 2020 /etc/crontab

/etc/cron.d:
total 20
drwxr-xr-x 2 root root 4096 Feb  3 2025 .
drwxr-xr-x 99 root root 4096 May 21 03:26 ..
-rw-r--r-- 1 root root 102 Feb 13 2020 .placeholder
-rw-r--r-- 1 root root 201 Feb 14 2020 e2scrub_all
-rw-r--r-- 1 root root 189 Oct 26 2020 popularity-contest

/etc/cron.daily:
total 52
-rwxr-xr-x 2 root root 4096 Feb  3 2025 .
-rwxr-xr-x 99 root root 4096 May 21 03:26 ..
-rw-r--r-- 1 root root 102 Feb 13 2020 .placeholder
-rwxr-xr-x 1 root root 539 Apr 13 2020 apache2
-rwxr-xr-x 1 root root 376 Dec  4 2019 apport
-rwxr-xr-x 1 root root 1478 Apr  9 2020 apt-compat
-rwxr-xr-x 1 root root 355 Dec 29 2017 bsdmaintutils
-rwxr-xr-x 1 root root 1187 Sep  5 2019 dpkg
-rwxr-xr-x 1 root root 377 Jan 21 2019 logrotate
-rwxr-xr-x 1 root root 1123 Feb 25 2020 man-db
-rwxr-xr-x 1 root root 4574 Jul 18 2019 popularity-contest
-rwxr-xr-x 1 root root 214 Apr  2 2020 update-notifier-common

/etc/cron.hourly:
total 12
drwxr-xr-x 2 root root 4096 Oct 26 2020 .
drwxr-xr-x 99 root root 4096 May 21 03:26 ..
-rw-r--r-- 1 root root 102 Feb 13 2020 .placeholder

/etc/cron.monthly:
total 12
drwxr-xr-x 2 root root 4096 Oct 26 2020 .
drwxr-xr-x 99 root root 4096 May 21 03:26 ..
-rw-r--r-- 1 root root 102 Feb 13 2020 .placeholder

/etc/cron.weekly:
total 20
drwxr-xr-x 2 root root 4096 Feb  3 2025 .
drwxr-xr-x 99 root root 4096 May 21 03:26 ..
-rw-r--r-- 1 root root 102 Feb 13 2020 .placeholder
-rwxr-xr-x 1 root root 813 Feb 25 2020 man-db
-rwxr-xr-x 1 root root 403 Apr 25 2022 update-notifier-common
tryhackme@linux3:~$

```

Figure 6. Review of user and system cron jobs, including scheduled maintenance scripts and automated task directories.

6. Linux Log Monitoring and Audit Review

System logging and monitoring are essential components of Linux security auditing and incident response. During this assessment, several important log locations were reviewed to validate logging functionality and identify available audit visibility across the operating system.

The review included:

- authentication logs
- system logs
- Apache web server logs

Authentication logs provide visibility into login activity, authentication attempts, and user access events. System logs record operational activity generated by services and applications running on the host. Apache logs provide web server request visibility and are commonly used during web application investigations and security monitoring operations.

Proper logging and log retention are important because they support:

- incident response investigations
- accountability and auditing
- suspicious activity detection
- operational troubleshooting
- compliance validation

```
tryhackme@linux3:~$ # Reviewing authentication logs
tryhackme@linux3:~$ ls -l /var/log/auth.log*
-rw-r----- 1 syslog adm 527 May 21 03:34 /var/log/auth.log
-rw-r----- 1 syslog adm 5974 May 21 03:26 /var/log/auth.log.1
-rw-r----- 1 syslog adm 1356 Feb 3 2025 /var/log/auth.log.2.gz
-rw-r----- 1 syslog adm 1606 Oct 18 2022 /var/log/auth.log.3.gz
tryhackme@linux3:~$ # Reviewing system logs
tryhackme@linux3:~$ ls -l /var/log/syslog*
-rw-r----- 1 syslog adm 123807 May 21 03:57 /var/log/syslog
-rw-r----- 1 syslog adm 421244 May 21 03:26 /var/log/syslog.1
-rw-r----- 1 syslog adm 74952 Feb 3 2025 /var/log/syslog.2.gz
-rw-r----- 1 syslog adm 132649 Oct 18 2022 /var/log/syslog.3.gz
tryhackme@linux3:~$ # Reviewing Apache access logs
tryhackme@linux3:~$ ls -l /var/log/apache2
total 12
-rw-r----- 1 root adm 0 Feb 3 2025 access.log
-rwxrwxrwx 1 tryhackme tryhackme 209 May 4 2021 access.log.1
-rw-r----- 1 root adm 0 Feb 3 2025 error.log
-rw-r----- 1 root adm 810 Oct 18 2022 error.log.1
-rwxrwxrwx 1 root adm 464 May 5 2021 error.log.2.gz
-rw-r----- 1 root adm 0 May 4 2021 other_vhosts_access.log
tryhackme@linux3:~$
```

Figure 7. Review of authentication logs, system logs, and Apache web server logging directories.

7. Sensitive File Permission Review

Linux file permissions were reviewed to validate protections applied to sensitive operating system files and security configurations. Protecting system credential files is an important

security requirement because unauthorized access to these files may expose password hashes or allow unauthorized system modification.

The audit reviewed permissions for:

- /etc/passwd
- /etc/shadow
- /etc/ssh/sshd_config

Results confirmed that:

- /etc/shadow maintained highly restrictive permissions
- root ownership was properly enforced
- SSH configuration files were protected from unauthorized modification

These permission settings help support account security, access control enforcement, and secure remote administration practices.

```
tryhackme@linux3:~$ # Reviewing sensitive file permissions
tryhackme@linux3:~$ ls -l /etc/passwd /etc/shadow
-rw-r--r-- 1 root root 1954 Feb  3 2025 /etc/passwd
-rw-r----- 1 root shadow 1133 May 21 03:26 /etc/shadow
tryhackme@linux3:~$ # Reviewing SSH configuration permissions
tryhackme@linux3:~$ ls -l /etc/ssh/sshd_config
-rw-r--r-- 1 root root 3288 May  4 2021 /etc/ssh/sshd_config
tryhackme@linux3:~$
```

Figure 8. Review of sensitive Linux file permissions and SSH configuration protections.

8. Network Service Enumeration

The `ss -tulnp` command was used to identify listening network services and exposed TCP/UDP ports within the Linux environment. Network service enumeration is an important hardening activity because unnecessary listening services may increase the attack surface of a system.

The review identified several listening services, including:

- SSH service listening on TCP port 22
- local service bindings

- active network sockets

Reviewing active network services helps administrators validate remote access exposure, identify unnecessary services, and improve system hardening visibility.

```
tryhackme@linux3:~$ # Reviewing listening network services
tryhackme@linux3:~$ ss -tulnp
```

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	127.0.0.53%lo:53	0.0.0.0:*	
udp	UNCONN	0	0	10.67.133.119%eth0:68	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.53%lo:53	0.0.0.0:*	
tcp	LISTEN	0	128	0.0.0.0:22	0.0.0.0:*	
tcp	LISTEN	0	128	:::22	:::*	

```
tryhackme@linux3:~$
```

Figure 9. Review of listening Linux network services and exposed TCP/UDP ports.

9. Installed Security Package Review

Installed Linux packages were reviewed to identify security-related components supporting system hardening and operational security. Security package auditing is useful because missing or outdated security packages may reduce overall defensive capabilities within the operating system.

The review identified several important security-related packages, including:

- OpenSSH server components
- UFW firewall utilities
- AppArmor security modules
- audit-related libraries

These packages contribute to:

- secure remote administration
- host firewall management
- mandatory access control enforcement
- logging and auditing support

```
tryhackme@linux3:~$ # Reviewing installed security-related packages
tryhackme@linux3:~$ dpkg -l | grep -E "ssh|audit|ufw|apparmor"
ii  apparmor                2.13.3-7ubuntu5.4      amd64      user-space parser utility for AppArmor
ii  ec2-instance-connect    1.1.12+dfsg1-0ubuntu3.20.04.1 all        Configures ssh daemon to accept EC2 Instance Connect ssh keys
ii  libapparmor1:amd64     2.13.3-7ubuntu5.4      amd64      changehat AppArmor library
ii  libaudit-common        1:2.8.5-2ubuntu6       all        Dynamic library for security auditing - common files
ii  libaudit1:amd64       1:2.8.5-2ubuntu6       amd64      Dynamic library for security auditing
ii  libssh-4:amd64        0.9.3-2ubuntu2.5       amd64      tiny C SSH library (OpenSSL flavor)
ii  openssh-client         1:8.2p1-4ubuntu0.11    amd64      secure shell (SSH) client, for secure access to remote machines
ii  openssh-server         1:8.2p1-4ubuntu0.11    amd64      secure shell (SSH) server, for secure access from remote machines
ii  openssh-sftp-server    1:8.2p1-4ubuntu0.11    amd64      secure shell (SSH) sftp server module, for SFTP access from remote machines
ii  ssh-import-id          5.10-0ubuntu1          all        securely retrieve an SSH public key and install it locally
ii  ufw                    0.36-6ubuntu1.1        all        program for managing a Netfilter firewall
tryhackme@linux3:~$
```

Figure 10. Review of installed Linux security-related packages and services.

10. Least Privilege Validation

The principle of least privilege is a core cybersecurity concept that restricts users to only the permissions necessary to perform authorized tasks. Limiting administrative access helps reduce the risk of unauthorized system modifications, privilege abuse, and accidental configuration changes.

During the audit, an attempt was made to review firewall status information using elevated privileges. The results confirmed that the tryhackme account was not authorized to execute privileged firewall management commands through sudo access.

Restricting administrative permissions helps strengthen accountability and supports secure access control practices commonly required within STIG and NIST-aligned environments.

```
tryhackme@linux3:~$ sudo ufw status verbose
[sudo] password for tryhackme:
tryhackme is not in the sudoers file. This incident will be reported.
tryhackme@linux3:~$
```

Figure 11. Validation of restricted sudo privileges and least privilege enforcement.

11. World-Writable File Validation

A filesystem permission review was conducted to identify world-writable files located within user home directories. World-writable files may present security risks because any local user can potentially modify the contents of those files.

The audit did not identify any world-writable files within the /home directory structure. The absence of insecure writable files indicates stronger filesystem permission management and reduced exposure to unauthorized file modification risks.

Reviewing filesystem permissions is an important hardening activity commonly included within Linux STIG compliance assessments.

```
tryhackme@linux3:~$ find /home -type f -perm -002 2>/dev/null
tryhackme@linux3:~$
```

Figure 12. Validation check for world-writable files within Linux home directories.

12. Password Policy Configuration Review

Password policy settings were reviewed using the `/etc/login.defs` configuration file. Password management policies are important because weak or improperly configured password controls may increase exposure to credential compromise and unauthorized access.

The review identified configuration settings related to:

- maximum password age
- minimum password age
- password expiration warning periods

These settings help support account security management and encourage periodic credential updates within Linux environments.

Strong password policy enforcement is commonly associated with:

- NIST identity and authentication controls
- STIG account management requirements
- enterprise security hardening practices

```
tryhackme@linux3:~$ cat /etc/login.defs | grep PASS
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_WARN_AGE Number of days warning given before a password expires.
PASS_MAX_DAYS 99999
PASS_MIN_DAYS 0
PASS_WARN_AGE 7
#PASS_CHANGE_TRIES
#PASS_ALWAYS_WARN
#PASS_MIN_LEN
#PASS_MAX_LEN
# NO_PASSWORD_CONSOLE
tryhackme@linux3:~$
```

Figure 13. Review Linux password aging and account policy configuration settings.

13. Filesystem Usage Review

Filesystem utilization was reviewed to identify mounted storage volumes and current disk usage across the Linux environment. Monitoring storage utilization is important because insufficient disk space may impact system stability, logging functionality, and operational availability.

The review identified:

- mounted root filesystems
- temporary storage locations
- loop-mounted snap package filesystems
- current storage utilization percentages

Filesystem monitoring supports operational awareness and helps administrators maintain system reliability and logging integrity.

```
tryhackne@linux3:~$ df -h
Filesystem      Size  Used Avail Use% Mounted on
/dev/root        30G   3.2G   26G   11% /
devtmpfs         973M    0   973M    0% /dev
tmpfs            981M    0   981M    0% /dev/shm
tmpfs            197M  888K   196M    1% /run
tmpfs            5.0M    0    5.0M    0% /run/lock
tmpfs            981M    0   981M    0% /sys/fs/cgroup
/dev/loop0        25M    25M    0 100% /snap/amazon-ssm-agent/6312
/dev/loop3        56M    56M    0 100% /snap/core18/2566
/dev/loop1        27M    27M    0 100% /snap/amazon-ssm-agent/9881
/dev/loop2       105M   105M    0 100% /snap/core/17200
/dev/loop4        56M    56M    0 100% /snap/core18/2846
/dev/loop5        64M    64M    0 100% /snap/core20/1623
/dev/loop6        64M    64M    0 100% /snap/core20/2434
/dev/loop7        74M    74M    0 100% /snap/core22/1748
/dev/loop8        68M    68M    0 100% /snap/lxd/22753
/dev/loop9        92M    92M    0 100% /snap/lxd/29619
tmpfs            197M    0   197M    0% /run/user/1001
tryhackne@linux3:~$
```

Figure 14. Review of mounted Linux filesystems and storage utilization.

14. Operating System and Kernel Validation

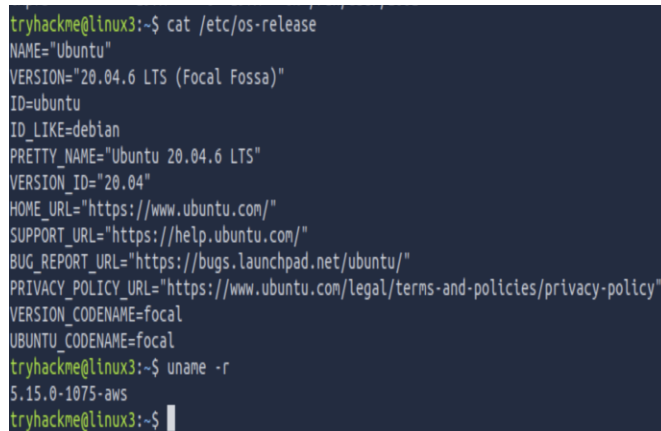
Operating system and kernel version information were reviewed to establish baseline platform identification for the Linux environment. Version validation is important because outdated operating systems and kernels may contain known vulnerabilities or unsupported software components.

The review confirmed:

- Ubuntu Linux distribution information
- operating system release details
- Linux kernel version information

Maintaining awareness of operating system and kernel versions supports:

- vulnerability management
- patch management
- security baseline validation
- compliance documentation



```
tryhackme@linux3:~$ cat /etc/os-release
NAME="Ubuntu"
VERSION="20.04.6 LTS (Focal Fossa)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 20.04.6 LTS"
VERSION_ID="20.04"
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
VERSION_CODENAME=focal
UBUNTU_CODENAME=focal
tryhackme@linux3:~$ uname -r
5.15.0-1075-aws
tryhackme@linux3:~$
```

Figure 15. Ubuntu operating system and Linux kernel version validation.

15. Login History and Session Monitoring

User login activity and session history were reviewed using the last command. Monitoring login activity is important because it provides visibility into user access patterns, remote login sessions, reboot activity, and authentication events occurring within the operating system.

The review identified:

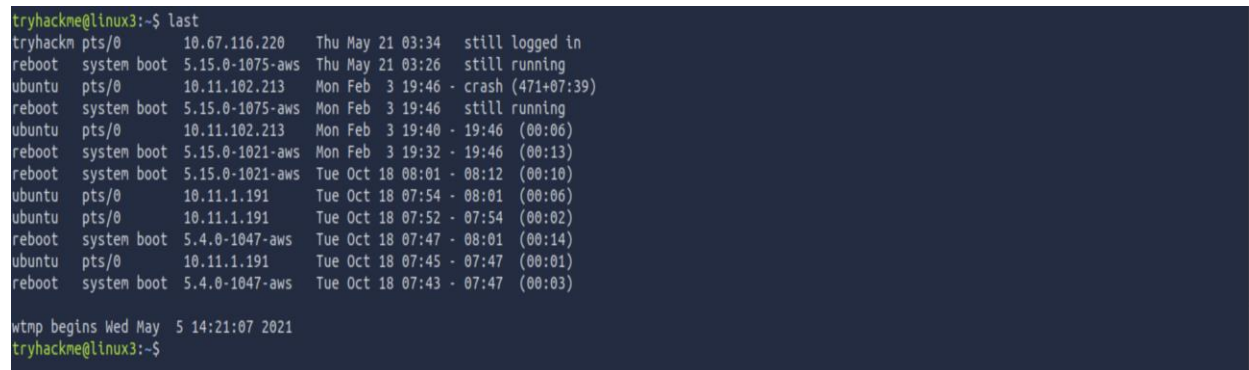
- active and historical user login sessions
- remote SSH connections
- system reboot events
- session timestamps and source addresses

Login monitoring supports:

- security auditing
- incident response investigations

- user accountability
- authentication tracking
- suspicious activity detection

Reviewing historical login records helps administrators identify unusual access behavior and maintain operational visibility across Linux systems.



```
tryhackme@linux3:~$ last
tryhackme pts/0    10.67.116.220    Thu May 21 03:34    still logged in
reboot    system boot    5.15.0-1075-aws  Thu May 21 03:26    still running
ubuntu   pts/0        10.11.102.213   Mon Feb  3 19:46 - crash (471+07:39)
reboot    system boot    5.15.0-1075-aws  Mon Feb  3 19:46    still running
ubuntu   pts/0        10.11.102.213   Mon Feb  3 19:40 - 19:46 (00:06)
reboot    system boot    5.15.0-1021-aws  Mon Feb  3 19:32 - 19:46 (00:13)
reboot    system boot    5.15.0-1021-aws  Tue Oct 18 08:01 - 08:12 (00:10)
ubuntu   pts/0        10.11.1.191     Tue Oct 18 07:54 - 08:01 (00:06)
ubuntu   pts/0        10.11.1.191     Tue Oct 18 07:52 - 07:54 (00:02)
reboot    system boot    5.4.0-1047-aws  Tue Oct 18 07:47 - 08:01 (00:14)
ubuntu   pts/0        10.11.1.191     Tue Oct 18 07:45 - 07:47 (00:01)
reboot    system boot    5.4.0-1047-aws  Tue Oct 18 07:43 - 07:47 (00:03)

wtmp begins Wed May  5 14:21:07 2021
tryhackme@linux3:~$
```

Figure 16. Review of Linux login history and user session activity using the last command.

16. Firewall Kernel Module Review

The audit also reviewed loaded Linux kernel modules associated with packet filtering and firewall functionality. Kernel module inspection helps validate whether important networking and filtering components are loaded within the operating system.

The review identified several networking and packet-filtering modules, including:

- ip_tables
- x_tables
- nf_conntrack

These modules support:

- packet filtering
- connection tracking
- firewall rule processing
- network traffic inspection

Reviewing loaded firewall-related kernel modules provides additional visibility into the system's networking security architecture and supports Linux hardening validation activities.

```
tryhackme@linux3:~$ lsmod | grep -E "ip_tables|nf_conntrack|x_tables"
ip_tables      32768  0
x_tables       53248  1 ip_tables
tryhackme@linux3:~$
```

Figure 17. Review of loaded Linux firewall and packet-filtering kernel modules.

17. Key Findings

The Linux STIG-style security audit identified multiple configurations and operational characteristics relevant to Linux hardening and compliance validation. Overall, the system demonstrated several secure baseline configurations related to permissions management, service organization, and logging visibility.

Key observations identified during the assessment included:

- Active SSH remote administration services were enabled on TCP port 22
- Password authentication remained enabled within the SSH configuration
- Administrative privileges were restricted through sudo access limitations
- Sensitive files such as /etc/shadow maintained restrictive permissions
- System logging and authentication logs were operational
- Security-related packages including AppArmor and OpenSSH were installed
- No world-writable files were identified within user home directories
- Cron scheduling functionality and automated maintenance tasks were active

Several findings also highlighted opportunities for additional hardening improvements, including:

- reducing SSH password-based authentication exposure
- implementing stronger centralized auditing controls
- expanding firewall visibility and validation capabilities

- strengthening account security policies

Overall, the audit demonstrated a functional Linux environment with multiple baseline security controls already present while also identifying several areas where additional hardening could further improve the system's security posture.

18. Security Recommendations

Based on the findings identified during the Linux STIG-style audit, several recommendations can further improve the overall security posture of the system and reduce potential exposure to unauthorized access or configuration weaknesses.

Recommended Security Improvements

a. Disable SSH Password Authentication

Password-based SSH authentication increases exposure to brute-force and credential-based attacks. Implementing SSH key-based authentication would strengthen remote access security and reduce credential exposure risks.

b. Restrict SSH Access

Remote administration access should be restricted to authorized users and trusted network ranges whenever possible. Limiting SSH exposure reduces attack surface visibility and unauthorized connection attempts.

c. Implement Multi-Factor Authentication (MFA)

Adding MFA for privileged or remote administrative access can provide an additional security layer against credential compromise and unauthorized access attempts.

d. Expand Audit Logging Capabilities

Additional auditing controls such as Auditd rule expansion and centralized log forwarding can improve visibility into user activity, authentication events, and system changes.

e. Regularly Review Running Services

Periodic service reviews should be performed to identify unnecessary or insecure services that may increase attack surface exposure.

f. Continue File Permission Auditing

Sensitive system files and directories should be periodically reviewed to ensure restrictive permissions remain properly enforced.

g. Monitor Scheduled Tasks and Cron Jobs

Scheduled automation tasks should be reviewed regularly to detect unauthorized persistence mechanisms or suspicious automated scripts.

h. Maintain System Updates and Patch Management

Operating system packages, security tools, and kernel versions should be updated regularly to reduce exposure to known vulnerabilities.

19. NIST 800-53 / RMF Security Control Alignment

The Linux STIG-style security audit performed in this project aligns with multiple NIST 800-53 security controls commonly used within the Risk Management Framework (RMF) process for federal systems and government contractors.

The audit activities focused on system hardening validation, access control review, logging visibility, authentication monitoring, and configuration of security assessments.

NIST Control	Control Name	Audit Activity
AC-2	Account Management	Reviewed local user accounts and sudo group membership
AC-6	Least Privilege	Verified privilege separation and sudo access restrictions
AU-2	Event Logging	Reviewed authentication logs and system log files
AU-6	Audit Review and Analysis	Examined Linux log sources for security monitoring visibility
CM-6	Configuration Settings	Reviewed SSH configuration and password policy settings
CM-7	Least Functionality	Identified active services and running processes
IA-5	Authenticator Management	Reviewed password aging and password policy configurations
SC-7	Boundary Protection	Examined listening ports and firewall-related configurations
SI-4	System Monitoring	Reviewed cron jobs, services, and monitoring-related configurations

RMF Relevance

This project supports several RMF assessment objectives by demonstrating practical security validation techniques commonly used during system hardening reviews, compliance assessments, and operational security monitoring activities.

The audit process reflects foundational security assessment procedures often associated with:

- Security Control Assessments (SCA)
- Continuous Monitoring (ConMon)
- Vulnerability Assessment Activities
- Linux STIG Compliance Reviews
- Baseline Security Validation

The project also demonstrates familiarity with Linux administrative security practices relevant to cybersecurity analyst, SOC analyst, GRC analyst, and federal contractor environments.

20. MITRE ATT&CK Mapping

The Linux STIG-style audit findings can also be mapped to several MITRE ATT&CK techniques that are commonly associated with Linux-based attacks and post-compromise activities. While this project focused on defensive auditing rather than active exploitation, the reviewed configurations and system artifacts relate directly to attacker persistence, privilege escalation, credential access, and system discovery behaviors.

MITRE Technique ID	Technique Name	Related Audit Activity
T1082	System Information Discovery	Collected OS version, hostname, kernel, and network configuration information
T1057	Process Discovery	Reviewed active running processes using ps aux
T1016	System Network Configuration Discovery	Enumerated network interfaces and listening services
T1046	Network Service Discovery	Reviewed open ports and active services using ss -tulnp
T1053.003	Scheduled Task/Job: Cron	Reviewed user and system cron jobs for persistence mechanisms

T1078	Valid Accounts	Reviewed local user accounts and privilege memberships
T1110	Brute Force	Examined authentication logs related to SSH access activity
T1021.004	Remote Services: SSH	Reviewed SSH daemon configuration and exposed SSH services
T1543	Create or Modify System Process	Reviewed enabled system services and startup configurations
T1069	Permission Groups Discovery	Examined sudo group membership and privilege assignments

Security Relevance

Mapping Linux administrative and audit activities to the MITRE ATT&CK framework helps security teams better understand how normal system configurations may be abused by attackers during different phases of an intrusion.

For example:

- Cron jobs may be abused for persistence
- Weak SSH configurations may allow unauthorized remote access
- Excessive sudo privileges may increase privilege escalation risk
- Open network services may expand attack surface exposure
- Poor logging visibility may reduce detection capability

Understanding these relationships improves defensive visibility and strengthens both security monitoring and hardening efforts.

Project Value

This mapping demonstrates practical blue team awareness by connecting Linux system administration reviews with real-world attacker techniques used during compromise attempts against Linux infrastructure.

The project reflects foundational SOC analyst, Linux security monitoring, and GRC-oriented assessment skills commonly required in cybersecurity operations and federal contractor environments.

21. Conclusion

Conclusion

This project demonstrated a Linux STIG-style security audit performed against an Ubuntu Linux environment using administrative review, system enumeration, logging analysis, and security configuration validation techniques. The assessment reviewed running services, SSH configurations, scheduled tasks, file permissions, authentication controls, logging visibility, and network service exposure.

The audit identified several baseline security protections already present within the environment, including restricted sudo privileges, protected system files, operational logging functionality, and installed security-related packages. The review also identified opportunities for additional hardening improvements such as stronger SSH authentication controls and expanded audit visibility.

Overall, the project strengthened practical Linux security auditing skills and demonstrated foundational knowledge relevant to Linux hardening, SOC operations, STIG compliance concepts, NIST security controls, and cybersecurity governance-focused environments.